

基于 MySQL 数据库的数据安全应用设计

李艳杰

(山东华宇工学院 信息工程学院, 山东 德州 253034)

摘 要: 信息系统工程领域对数据安全的要求比较高, MySQL 数据库管理系统普遍应用于各种信息系统应用软件的开发之中, 而角色与权限设计不仅关乎数据库中数据保密性的性能高低, 也关系到用户使用数据库的最低要求。在对数据库的安全性进行设计时, 为了保证数据的安全性和可靠性, 提出通过设置角色和权限实现对数据的安全访问, 然后通过编写代码进行实验, 以验证此方式解决数据库中数据安全问题的有效性。

关键词: 数据安全; 应用设计; MySQL

中图分类号: TP311.1

文献标识码: A

文章编号: 2096-4706 (2023) 12-0151-04

Design of Data Security Application Based on MySQL Database

LI Yanjie

(School of Information Engineering, Shandong Huayu University of Technology, Dezhou 253034, China)

Abstract: The field of information system engineering has high requirements for data security. MySQL database management system is widely used in the development of various information system application software, and the design of roles and permissions is not only related to the performance of data confidentiality in the database, but also to the minimum requirements for users to use the database. When designing the security of the database, in order to ensure the security and reliability of the data, it is proposed to set roles and permissions to achieve secure access to the data. Then, code is written for experiments to verify the effectiveness of this method in solving security issues of data in the database.

Keywords: data security; application design; MySQL

0 引 言

在当今大数据时代, 各行各业都离不开计算机信息技术, 特别是利用信息系统应用软件对业务进行处理, 系统后台会存放大量数据, 这也使得数据变得越来越重要, 而作为数据的主要存储器之一的数据库管理系统就承担起了保护数据的重要角色。在开发信息系统过程中, 对数据库中数据的安全设计必须给予重视, 才能提高数据的安全性。

目前主流的数据库管理系统有 Oracle、SQL Server、MySQL 等, 任何一个数据库都要考虑数据安全方面的设计, 此文以 MySQL 数据库管理系统为例对数据安全进行论述, 其中一类安全问题是指数据库中敏感数据被多个合法用户查询获取, 在使用过程中发生泄密事故或恶意篡改, 数据库管理员需要追踪和熟悉哪些用户曾访问数据以及这些用户的访问权限和操作, 用于解决相关事故责任。

对数据库中存放的关键数据, 基本上都有保密要求, 即限制部分用户对数据的访问, 在访问的过程中也会限制用户的访问权限, 不同用户根据角色的不同, 管理员要设置不同的访问权限, 以保证数据库中数据的安全。

1 存放用户账户的权限表

为了方便管理员管理用户, 需要为众多用户设置账户和访问权限, 同时为了方便管理, 数据库管理系统设置了重要的表存放账户和权限, 在 MySQL 数据库中用户及权限相关的表主要有 4 个, 即 user 表、db 表、tables_priv 表和 columns_priv 表。

user 表是最重要的表, 包含用户、权限、安全和资源控制 4 类共计 42 个字段, 用户包含用户名、主机名和密码。权限共计 29 个, 以 _priv 结尾, 例如 update_priv 等。针对 user 表, 里面存放全局级的权限。

db 表是非常重要的表之一, 存放为用户指定的某个或某些数据库的操作权限。仅存放用户名、主机名及权限。针对 db 表, 里面存放数据库级的权限。

tables_priv 表, 用于存放固定数据库下的一个表和多个表的用户和用户权限信息。

columns_priv 表, 用于存放固定数据库下固定表的一列或多列的用户和用户权限信息。

4 个表均存放用户和权限, 具体区别见如表 1 所示。

2 账户和账户权限设计

在 MySQL 数据库管理系统下, 账户的创建和验证与其他数据库管理系统有所不同, 在单机系统中, 为了能够进行验证, 数据库设计时, 需要在 Windows 命令行下登录才能够进行验证。

收稿日期: 2023-01-16

基金项目: 山东省本科高校教学改革研究

项目 (M2020222)

表 1 权限表的区别

表名称	区别	举例
use	存放全局级的权限	所有的用户账户都会存放在此表中，不管此用户是否具有权限，且密码会存放在此表中，主要字段：host、user、password、select_priv、insert_priv、update_priv 等
db	存放数据库级的权限	如果指定用户可以访问某个数据库或者某些数据库，则此用户存放在此表中，仅存放用户名、主机名和权限，用户密码不存放，主要字段：host、db、user、select_priv、insert_priv、update_priv 等，特别是 db 字段用于指定访问固定的数据库
tables_priv	存放表级的权限	如果指定用户可以访问某个数据库或者某些数据库下的某些表，则此用户存放在此表中，仅存放用户名、主机名和权限，用户密码不存放，主要字段：host、db、user、table_name、table_priv、column_priv 等，特别是字段 table_name 用于指定访问固定的数据库下的固定数据表
columns_priv	存放列级的权限	如果指定用户可以访问某个数据库或者某些数据库下的某些表的某几列，则此用户存放在此表中，仅存放用户名、主机名和权限，用户密码不存放，主要字段：host、db、user、table_name、column_name 等，特别是 column_name 字段用于指定访问固定数据库下的固定数据表的固定列

2.1 从 Windows 命令行登录到 MySQL 数据库中

登录过程如下：开始—运行—输入 cmd，进入 Windows 命令行 -- 输入参数，即登录命令（MySQL -u 用户名 -h 主机名 -p 密码），第一次登录创建用户账户需要超级管理员 root 用户进行登录。

注意事项：登录命令如果执行，必须切换到 MySQL 的安装文件 bin 目录下，因为很多用户在安装 MySQL 时，并没有配置 path 变量，此时，Windows 命令行无法识别命名，所以无法执行。例如 C:\Users\Administrator>mysql -u root -h localhost -p，错误提示：“mysql”不是内部或外部命令，也不是可运行的程序或批处理文件。

另外，如果 MySQL 服务器未开启，也会显示命令无效，

所以也必须保证数据库服务器处于开启的状态。下面是以超级管理员进入 MySQL 数据库管理系统，在第一次创建用户的时候，仅有 root 超级管理员才有权限创建其他用户，输入密码便可以登录到 MySQL 数据库命令行。登录过程如图 1 所示。

输入密码，即可进入 MySQL 命令行。代码为：

c:\wamp\bin\mysql\mysql5.5.24\bin>mysql -u root -h localhost -p

Enter password:-- 此处输入密码，后面出现 MySQL 的欢迎界面和连接所花费的时间等。

mysql>-- 最终以此命令符出现，此时光标会在 mysql> 后面停留，等待输入命令。

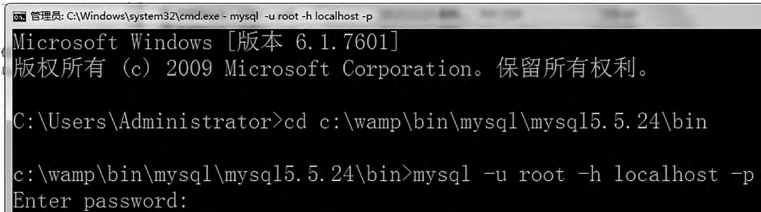


图 1 Windows 命令行登录过程图

2.2 创建用户并赋予权限

在 MySQL 数据库管理系统下，在此建立一个数据库 b 和数据库 a，在数据库 b 下建立一个数据表 book，并在 book 数据表中设计一个整型字段 bid 代表图书编号，可以输入一条记录为 1，为了进行验证，再建立一个 book2 数据表，字段和记录可以随意设计，在此利用简单的数据表展示创建用户账户并赋予权限的过程。部分代码为：

```
Create database a;
Create database b;
create table book(bidint);
insert into book values(1);
create table book2(bidint,bname char(4));
```

下面设计第一个用户 a1，密码为：test1，此用户的权限设计为仅能操作数据库 b，利用如下格式设计代码，即利用 grant 创建新用户，并赋予权限，语法规则：Grant 权限类型 on 数据库.数据表 to 用户名 @ 主机名 identified

by password[user@host identified by password][with grant option]。注意：权限类型表示赋予用户的权限类型（例如：select、alter、reload、excute、event 等），数据库.数据表代表权限的级别，一个 * 代表当前数据库中的所有表，*. * 代表所有数据库下的所有表，db_name.* 代表固定数据库中的所有表，db_name.tbl_name 代表固定数据库中的固定表和视图，db_name.routine_name 代表固定数据库中的固定存储过程和函数，user@host 代表用户名和主机名，password 代表密码，而 [with grant option] 则代表该用户可以对其他用户赋予权限，其他命令为固定写法。此代码为：

grant all on b.* to 'a1'@'localhost' identified by 'test1';
具体代码即执行过程如图 2 所示。

下面设计第二个用户 a2，密码为：test2，设计权限为仅能查看数据库 b 下的 book 表，此代码为：

grant select on b.book to 'a2'@'localhost' identified by 'test2';
具体代码即执行过程如图 3 所示。

```
mysql> grant all on b.* to 'a1'@'localhost' identified by 'test1';  
Query OK, 0 rows affected (0.08 sec)
```

图 2 第一个用户代码

```
mysql> grant select on b.book to 'a2'@'localhost' identified by 'test2';  
Query OK, 0 rows affected (0.00 sec)
```

图 3 第二个用户代码

3 验证用户权限是否有作用

验证用户是否具有对数据的访问权限，也必须打开 Windows 命令行，以此用户登录和密码登录到数据库管理系统，在进行验证之前，必须退出超级管理员的界面，重新进入，退出过程可以使用代码 quit，下面验证第一个用户的权限。登录过程如图 4 所示。

用户 a1 仅能访问 b 数据库，不能访问 a 数据库，下面是验证过程，通过下面的验证可以看出，用户 a1 对数据库 a 的访问权限受到限制，当访问数据库 a 的时候，如图 5 中的

错误提示代表针对用户 a1 访问被拒绝，但可以访问数据库 b，从而保证数据的安全性。

同理验证第二个用户 a2，以第二个用户登录，第二个用户可以查询数据库 b 下的 book 表信息，但不能查询 book2 数据表信息，因为没有权限，通过此代码：ERROR 1142 (42000): SELECT command denied to user 'a2'@'localhost' for table 'book2' 实验得出，用户 a2 的访问被拒绝，从而得出每个用户必须在自己权限范围内访问数据。如图 6 所示。

```
管理员: C:\Windows\system32\cmd.exe - mysql -u a1 -h localhost -ptest1  
c:\wamp\bin\mysql\mysql5.5.24\bin>mysql -u a1 -h localhost -ptest1  
Welcome to the MySQL monitor.  Commands end with ; or \g.  
Your MySQL connection id is 8  
Server version: 5.5.24-log MySQL Community Server (GPL)  
  
Copyright (c) 2000, 2011, Oracle and/or its affiliates. All rights reserved.  
  
Oracle is a registered trademark of Oracle Corporation and/or its affiliates. Other names may be trademarks of their respective owners.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input  
  
mysql>
```

图 4 第一个用户登录过程

```
mysql> use a;  
ERROR 1044 (42000): Access denied for user 'a1'@'localhost' to database 'a'  
mysql> use b;  
Database changed  
mysql>
```

图 5 第一个用户验证过程

```
mysql> use b;  
Database changed  
mysql> select * from book;  
+-----+  
| bid |  
+-----+  
| 1 |  
+-----+  
1 row in set (0.30 sec)  
  
mysql> select * from book2;  
ERROR 1142 (42000): SELECT command denied to user 'a2'@'localhost' for table 'book2'
```

图 6 第二个用户验证过程

4 用户账户在权限表中的体现

根据前面提到的权限表，所有用户账户均存放在 user 表中，不管是否具有权限，并且权限在 user 表中的没有任何

权限。通过查询 select_priv 字段可以得出全部为 N，代表没有权限。代码如下：

```
mysql> select user,password,select_priv from mysql.user;
```


查询后在 MySQL 命令行中的显示结构如下:

user	password	select_priv
a2	*7CEB3FDE5F7A9C4CE5FBE610D7D8EDA62EBE5F4E	N
a1	*06C0BF5B64ECE2F648B5F048A71903906BA08E5C	N

不同权限的用户名和权限存放在不同的表中。由于为用户 a1 指定了仅能访问固定数据库 a, 具有对数据库访问的所有权限, 以 db、select_priv 等字段显示为例, 结果为 Y, 代表具有查询等所有权限。所以属于数据库级别的权限, 应该存放在 db 表中。如图 7 所示。

由于为用户 a2 指定了仅能查询固定数据库 b 下的固

定数据表 book, 具体到某个固定的数据表, 所以属于表级别的权限, 用户 a2 应该存放在 tables_priv 表中, 以 user、db、table_name、table_priv 字段显示为例, 体现了用户、数据库、数据表和权限, 代码为:

```
mysql> select user,db,table_name,table_priv from mysql.tables_priv where user='a2';
```

user	db	table_name	table_priv
a2	b	book	Select

```
mysql> select user,db,select_priv from mysql.db where user='a1';
```

user	db	select_priv
a1	b	Y

1 row in set (0.06 sec)

图 7 用户 a1 在 db 表中的体现

5 结 论

本文以 MySQL 数据库为例, 结合数据库中对用户账户和权限的应用, 设计了两个用户和用户的权限, 通过实验结论得出设计的用户权限在用户访问数据的时候受到了限制, 管理员可以根据权限表对用户账户和权限进行管理, 并根据实际需求对用户的权限进行转移或撤销, 进而保证数据的安全。

参考文献:

- [1] 黄刘松, 张飞, 张学锋, 等. 基于网闸的异构数据库安全同步系统[J]. 大理大学学报, 2022, 7 (12): 25-30.
- [2] 林加华, 李志虹, 姜华. 一种基于安全散列加密算法的数

据库操作痕迹可证明追踪算法[J]. 现代计算机, 2022, 28 (22): 42-46.

[3] 王思君. 信息管理中计算机数据库技术的应用研究[J]. 信息与电脑: 理论版, 2022, 34 (7): 210-212.

[4] 田波. 大数据背景下的数据安全分析[J]. 网络安全技术与应用, 2021 (8): 58-59.

[5] 刘秀梅. 基于 MySQL 数据库安全的实验教学系统的设计与实现[D]. 北京: 北京邮电大学, 2017.

[6] 林森. 企业信息管理系统数据库安全控制策略分析[J]. 中国管理信息化, 2021, 24 (8): 120-121.

作者简介: 李艳杰(1978—), 女, 汉族, 山东德州人, 副教授, 硕士, 主要研究方向: 数据挖掘技术。

(上接 150 页) CDP 方式立马进行数据恢复, 整个恢复过程是将业务系统的虚拟机(包含操作系统、软件、应用程序、存储文件)全部恢复。但若现规划的云平台出现全部宕机, 例如: 地震、火灾等不可控因素。需要恢复至其他地方, 或在其他地方进行业务拉起, 保证业务不中断, 需要在异地部署同样环境的云环境方可实现。我们可以利用旧的服务器及存储设备, 将三台配置相同的两路服务器搭建一套计算虚拟化+外置存储方式的资源池, 在发生主数据中心全部宕机时, 核心业务系统会迁移至备数据中心, 保障核心业务不宕机。

6 结 论

CDP 技术是一种全新的容灾备份技术, CDP 技术与超融合服务器平台有机结合, 可以满足系统的镜像备份, 可以回到任意时间节点的历史轨迹。CDP 技术可以实现分层次恢复, 大部分数据恢复在本地即可完成, 具有独特的带宽优化功能, 可以确保在网络带宽有限的情况下快速异地恢复。在学校的数据灾备系统设计过程中, 发挥超融合服务器云平

台的作用, 合理利用现有的服务器, 搭建超融合集群服务和辅助集群, 通过万兆全光网络保障数据的全量和增量实时备份。在学校的灾备演练中, 数据恢复用时少, 数据没有丢失现象, 达到预期效果。

参考文献:

[1] 钱涛. 等保 2.0 背景下高职院校容灾备份技术的探究和实践[J]. 中国信息化, 2022 (1): 75-76+74.

[2] 张先哲, 马晓. 基于混合云的数据容灾备份方案研究[J]. 网络安全技术与应用, 2022 (2): 86-87.

[3] 李小林. 基于 CDP 技术建设同城数据容灾中心——设计与实践[J]. 中国信息化, 2021 (11): 85-87+84.

[4] 陈刘忠, 展亚南, 张旭东. 云平台容灾技术研究与实现[J]. 网络安全技术与应用, 2021 (5): 87-89.

[5] 陈波. 基于 CDP 技术的灾备系统实践[J]. 福建电脑, 2018, 34 (6): 142+162.

作者简介: 林家全(1987—), 男, 汉族, 贵州遵义人, 讲师, 网络信息中心副主任, 本科, 研究方向: 大数据技术、网络技术。